

CLASSIFIED · PRESENTER'S BRIEFING

PrivacyShield

How to explain every feature to the judges

This guide walks through the whole project in simple language: the one-minute pitch, a demo script you can follow click by click, every feature of the mobile app and the website with what to say about it, how it works underneath, the questions judges usually ask, and the things you should be careful not to overclaim.

How to read it: Part 1 and Part 2 are what you say on stage. Part 3 explains the system. Part 4 is a reference card for every feature: read the grey *Say* boxes out loud while practising. The red *Be accurate* boxes keep you safe from a tough judge.

Part	Contents
1	The pitch: problem, idea, why it is different
2	The 6-minute demo script
3	How the system is built, in simple words
4	Every feature: what it is, how to show it, what to say, how it works
5	Glossary: every technical word explained simply
6	Questions judges will ask, with answers
7	What not to overclaim
8	Checklist before you present

PART 1

The pitch

The problem. The average person has 80 to 100 online accounts. They are not separate: your email can reset the password of your bank, "Sign in with Google" opens dozens of apps, and most people reuse the same password. So one hacked account is rarely one problem. It is a chain reaction. Every existing tool checks accounts one at a time ("was this email in a breach?") and misses the chain.

The idea. PrivacyShield maps your accounts as a **network**, works out which account unlocks which, scores the real risk, simulates an attacker walking through it, and tells you the few fixes that break the chain. It does this for you and for your family, privately, with a tamper-evident record of every action.

The one-minute pitch (memorise this):

Say: "Hackers don't attack one account, they attack the chain. If someone gets your Gmail, they reset your PayPal, sign in to your Spotify, and try the same password on Instagram. PrivacyShield maps that chain. It pulls your accounts in from your phone or password manager, checks every one against real breach databases, and then literally hacks you in a simulation so you can watch it spread. Then it shows the two or three fixes that stop it, and replays the attack to prove they work. Families can protect each other without giving up their privacy, an AI assistant answers questions from your own records, and you can even prove your privacy score to a bank with a zero-knowledge proof without revealing it."

Three things that make it different:

- **Network thinking.** Risk comes from connections (password resets, SSO, reused passwords), not from accounts on their own.
- **It shows, not tells.** The Hack Me simulator turns an abstract risk score into a story you can watch, feel (the phone vibrates) and then fix.
- **Privacy by design.** Passwords never leave the phone, the leak check is anonymous, family members choose what to share, and the score can be proven without being revealed.

PART 2

The 6-minute demo script

Practise this order. Each step lists what to tap and the sentence to say. If anything fails live, switch to the **Sample network** in Hack Me: it needs no setup and always works.

Time	Do this	Say this
0:00	Open the app (splash: CLASSIFIED, file opening)	PrivacyShield treats your digital life like a case file.
0:15	Overview: watch the exposure scan run through every account	Every account I own is being checked right now: 2FA, reused passwords, breaches.
0:40	Point at the score dial, the stamp and the exhibits	My privacy score is [your number] out of 100. [N] accounts are high risk.
1:00	Scroll to Surveillance: radar and live scan	Each blip is one of my accounts. The riskier, the closer to the centre.
1:20	Keystone accounts	These are the accounts that unlock others. Lose Gmail and five more follow.
1:40	Tap OP-01 Hack Me, keep the suggested entry, Launch attack	Let's hack me. Watch.
2:40	Verdict: YOU'VE BEEN OWNED. Tap 'Replay it with the fixes done'	Eight and a half minutes, ten accounts. Now with the fixes: contained.
3:20	Family Shield: open a group, show invite code, member risk, nudge	My family's accounts are a risk to me too. Guardians see who needs help without reading anyone's data.
4:10	PrivacyBot: ask 'What should I fix first?'	The AI answers from my own records and cites them. It is retrieval-augmented, not guessing.
4:50	Audit log > ZKP: generate proof for 70, Verify, Tamper 1 byte	I can prove to a bank my score is above 70 without telling them my actual score. Change one byte: rejected.
5:40	Close: back to Overview	Map the chain, watch the attack, break it, prove it.

Before the demo, make sure the backend is running, the phone is plugged in by USB, and you have run a breach scan once so real breaches show. See Part 8.

PART 3

How the system is built

PrivacyShield has three parts that talk to each other over a normal web API (HTTPS / JSON):

Part	Built with	What it does
Mobile app	Flutter (Dart), runs on Android and iOS	The main experience: overview, Hack Me, Family Shield, scanners, fingerprint lock. Native Android code (Kotlin) for the biometric prompt, the encrypted key store and the installed-apps scan.
Website	Next.js + React + TypeScript	The same account data in a desktop dashboard: accounts, risk graph, breach scanner, leak check, PrivacyBot, family, timeline, reports, audit log, badges.
Backend (server)	Python, FastAPI, SQLAlchemy, SQLite	Stores accounts, runs the risk model, the attack simulator, breach scans, the AI pipeline, the hash chain and the zero-knowledge proofs. 39 automated tests.

Outside services it uses:

Service	Used for
Have I Been Pwned (HIBP)	The public catalogue of every known data breach, and the anonymous password-leak check (Pwned Passwords).
XposedOrNot	Free breach lookup by email address, and paste (data dump) monitoring for the dark web monitor.
Google Gemini	The language model behind PrivacyBot, privacy-policy analysis and AI insights.
Voyage AI (optional)	Text embeddings for hybrid search in PrivacyBot when a key is set.
Polygon Amoy (optional)	Public blockchain timestamps for the audit chain when a wallet key is set.

The flow, in one sentence: accounts come in (manually or via Smart Import) -> the backend links them into a graph (who resets whom, who signs in through whom, who shares a password) -> breach scans attach real breach records -> the risk engine scores every account and the whole network -> the app shows, simulates, fixes and records it.

The risk model (worth knowing, judges like it). Every account gets a score from five ingredients, each 0-100:

Ingredient	Weight	Meaning
Breach	30%	Breaches on that account, heavier if passwords leaked, lighter as they get older
Permissions	20%	Sensitive access the app has: SMS, location, camera, microphone, contacts...
Password reuse	20%	How many other accounts share the same password
Missing 2FA	15%	None = worst, SMS = weak, authenticator app = good, passkey = best
Cascade	15%	How much else an attacker reaches from here through the graph

"Keystone" accounts (ones that unlock 5 or more others) get a minimum risk floor. The network score weights valuable accounts (finance, email) more and subtracts points for every unprotected keystone. It is deterministic and explainable: the same inputs always give the same score, and every number can be traced back.

PART 4

Every feature, explained

Each card follows the same pattern. **Where** tells you where to find it (App = mobile, Web = website).

FEATURE 01

Sign up, sign in, fingerprint sign-in and app lock

Where: App: first screen, menu (top right) - Web: /login, /register

What it is, in plain words. A normal account system, plus two phone-only extras: you can sign in with your fingerprint instead of typing, and you can lock the whole app behind your fingerprint whenever you leave it.

How to show it:

- Sign in once, accept 'Sign in with fingerprint?', log out, then tap 'Sign in with fingerprint'.
- Menu (three dots, top right) > Enable biometric lock. Leave the app and come back: it is locked.

Say: “Even the app protecting your privacy is protected: fingerprint to get in, and it locks itself when you leave.”

How it works (if they ask): Passwords are hashed on the server (never stored readable) and you get a signed JSON Web Token that expires. On the phone, the token and the fingerprint-login details are encrypted with AES-256-GCM using a key held in Android's hardware-backed Keystore, and only released after Android's BiometricPrompt confirms your fingerprint or screen lock.

FEATURE 02

Overview (the case file)

Where: App: first tab - Web: /dashboard

What it is, in plain words. Your whole situation on one screen: a privacy score out of 100, the four key numbers, the live radar and scan, the risk spread, your keystone accounts and an ordered list of fixes.

How to show it:

- Open the app: the full-screen exposure scan checks every account (tap to skip).
- Point out the black ticker, SHIELD ACTIVE strip (real server response time), score dial and stamp.
- Scroll: threat radar, live scan console, operations, risk profile bar, keystones, orders (fixes).
- Tap a fix: it shows the score before and after, then 'I completed it' records it.

Say: “This is my exposure on the record. The score, what is at risk, which accounts are keystones, and the exact order to fix things in.”

How it works (if they ask): Everything comes from the risk model in Part 3. The radar places each account by its risk score; the console prints each account's real 2FA, reuse, breach and risk values; the heartbeat pings the server. Fix suggestions are found by simulating each possible fix and ranking by score gained per minute of effort.

FEATURE 03

Accounts

Where: App: Accounts tab - Web: /accounts

What it is, in plain words. The list of your online accounts with their details: category, email used, 2FA type, password group (which ones share a password), sign-in method (e.g. Sign in with Google), permissions and risk.

How to show it:

- Add an account by hand; show its risk updating.
- Set 'login method: Google SSO' and watch it link in the graph.

Say: "Each account is one node in my security network. The details decide how it connects to the others."

How it works (if they ask): Saving an account rebuilds the graph: the server derives links automatically (SSO, recovery email, shared password) and rescores everything.

FEATURE 04

Smart Import

Where: App: More > Smart Import

What it is, in plain words. Fills your account list for you, three ways: scan the apps installed on the phone; import a password-manager export (Google, Chrome, Bitwarden, 1Password, LastPass); or paste an email and find every website in it.

How to show it:

- Tap 'Scan installed apps': banks, UPI apps, social and shopping apps appear with categories and breach flags. Tick and add.
- Export from passwords.google.com > Settings > Export, then 'Choose CSV file'. It reports how many logins share a password.

Say: "Nobody wants to type 80 accounts. PrivacyShield finds them, and your passwords never leave your phone."

How it works (if they ask): Installed apps are matched against a catalogue of about 100 services (package name -> service, category, domain). The CSV is read on the phone; reused passwords are detected there and replaced by labels like 'reuse_1'. Only the site, login name and label are sent, and the server rejects any request that contains a password field.

BE ACCURATE: The phone scan sees installed apps, not accounts inside them, so you confirm each one before it is added.

FEATURE 05

Breach scanner

Where: App: Breaches tab - Web: /breaches

What it is, in plain words. Checks every account against real breach databases and records which breaches affect you, what leaked, and when.

How to show it:

- Tap scan. Show a confirmed breach (your email was in it) versus a service breach (the company was breached).
- Show 'found in a breach you haven't listed' alerts.

Say: "This is real data from Have I Been Pwned and XposedOrNot, not a demo list."

How it works (if they ask): It downloads the HIBP breach catalogue (cached) and matches each account's website, then looks up each email address on XposedOrNot. Confirmed account breaches create critical notifications and feed the risk score.

FEATURE 06

Password leak check

Where: App: More > Password Leak Check - Web: /check (works without an account)

What it is, in plain words. Type a password and see whether it has appeared in known leaks, and how many times.

How to show it:

- Type a common password like 'password123': it shows a huge number of leaks.
- Explain that the password itself was never sent.

Say: "Your password never leaves your device. We send only the first five characters of its fingerprint."

How it works (if they ask): This is the k-anonymity method: the password is hashed with SHA-1 on the device, only the first 5 hex characters are sent to the Pwned Passwords API, which returns hundreds of matching suffixes, and the device checks the rest locally.

FEATURE 07

Dark web monitor

Where: App: More > Dark Web Monitor

What it is, in plain words. Looks for your email addresses in leaked data dumps ("pastes") and breach exposures, and keeps a list of alerts you can mark resolved.

How to show it:

- Run a scan; open an alert; mark it resolved.

Say: "If your details show up in a dump, you hear about it here first."

How it works (if they ask): It queries XposedOrNot for paste and breach exposures of each email you use, stores new ones as alerts and notifies you.

BE ACCURATE: Say 'monitors leak and paste sources', not 'crawls the dark web': it uses public breach-intelligence APIs.

FEATURE 08

This phone (device audit)

Where: App: second tab

What it is, in plain words. Audits the phone itself: the apps installed and the dangerous powers they hold, plus device settings like screen lock, developer options, USB debugging and encryption.

How to show it:

- Show an app flagged for reading notifications or accessibility access.
- Tap an app to jump to its Android settings.

Say: “Your phone is an account too. An app that can read your notifications can read your 2FA codes.”

How it works (if they ask): Native Android code lists launchable apps with their granted permissions, accessibility services, notification listeners and device admins, then flags combinations (e.g. accessibility access = can read the screen).

FEATURE 09

QR privacy check

Where: App: More > QR Privacy Check

What it is, in plain words. Scan a QR code before trusting it: see where it really goes, whether it uses a secure connection, and your risk with that service if you have an account there.

How to show it:

- Scan a payment or website QR code.

Say: “QR codes hide where they take you. This shows the real destination first.”

How it works (if they ask): The camera decodes the QR on the phone; the app parses the link and checks it against your own accounts.

FEATURE 10

Risk graph

Where: App: More > Risk graph - Web: /graph

What it is, in plain words. A picture of your accounts as a network: dots are accounts, lines show how one can unlock another.

How to show it:

- Point at a red keystone with many lines.
- Tap an account, then 'Hack Me' to start an attack from it.

Say: “This is what attackers see: not a list, a map.”

How it works (if they ask): Edges are created automatically: SSO (provider -> app), recovery email (inbox -> account), password reuse (both ways). Users can also add data-sharing links.

FEATURE 11

HACK ME attack simulator

Where: App: Overview > OP-01, or More > Hack Me simulator

What it is, in plain words. Pretend one of your accounts is hacked and watch exactly how far the attacker gets: hop by hop, with a clock, a hacker console, and a damage report. Then replay it with your fixes done and watch it shrink.

How to show it:

- Choose 'Sample network' (always works) or 'My accounts'. Keep the MOST DANGEROUS suggestion. Launch.
- The phone vibrates and the map shakes each time an account falls; green BLOCKED stamps show 2FA stopping it.
- Read the verdict and consequences, then 'Replay it with the fixes done': ATTACK CONTAINED.

Say: “In eight and a half minutes one leaked Canva password gives an attacker ten accounts, including PayPal and the bank. Two fixes and the same attack stops at Canva.”

How it works (if they ask): It is a best-first graph search (like Dijkstra, maximising probability). Each hop has a success chance from security research intuition: SSO usually bypasses the target's 2FA; password resets are stopped by an authenticator app or passkey but only slowed by SMS (SIM swap); a reused password is stopped by any 2FA. Accounts below 15% likelihood count as defended. Each hop has a realistic time, giving 'time to full takeover'. 'After fixes' applies every recommended fix to a copy of the network and runs the same attack. Real runs are saved, so after you really fix things you can compare with last time.

BE ACCURATE: The probabilities are expert estimates, not measured statistics. Say 'a deterministic, explainable model'.

FEATURE 12

Family Shield

Where: App: More > Family Shield - Web: /family

What it is, in plain words. Protect your family or team together. Create a group, share an 8-character invite code, and see everyone's privacy score, who needs help, the risks you share, and a to-do list. Guardians can send a nudge.

How to show it:

- Create a group: the invite card shows the code with Share / Copy / New code.
- Join from another account. Choose Summary or Detailed sharing.
- Show 'What to do next', a member's card, 'Risks you share' and send a nudge.

Say: “My mum's hacked email can reset my accounts. Family Shield lets us watch out for each other without reading each other's data.”

How it works (if they ask): Roles: owner, guardian, member. Each member chooses what the group sees: Summary (score and counts) or Detailed (also which accounts are risky). Shared risks only compare members who chose Detailed. When a breach scan confirms a member's account was breached, the group's guardians get an alert automatically. If the owner leaves, ownership passes to a guardian or the longest-standing member.

FEATURE 13

PrivacyBot (AI assistant with RAG)

Where: App: More > PrivacyBot - Web: /ai-chat

What it is, in plain words. A chat assistant that answers questions about YOUR security, using your own records, and shows the sources it used.

How to show it:

- Ask: 'What should I fix first?' and 'Was any of my accounts in a breach with passwords?'
- Point at the numbered citations.

Say: "It does not make things up from the internet. It retrieves my records first and cites them."

How it works (if they ask): RAG = Retrieval-Augmented Generation. Two knowledge bases are indexed into chunks of about 900 characters: (1) your own records (risk overview, accounts, breaches, dark-web alerts, fixes, analysed policies), private to you; (2) the full Have I Been Pwned breach catalogue. A question is matched with BM25 keyword ranking (and, with a Voyage key, embeddings fused by Reciprocal Rank Fusion). The best 8 chunks go to Google Gemini as numbered documents; it must cite them like [2], and the app marks which sources were used.

FEATURE 14

AI insights

Where: App: More > AI Privacy Insights

What it is, in plain words. Four tools: a privacy-policy analyser (paste a website's policy link, get the red flags), breach predictions per account, a permission advisor, and a 'digital twin' red-team summary.

How to show it:

- Analyse a policy URL: risk flags like data selling or indefinite retention, plus an AI summary.
- Open breach predictions and the permission advisor.

Say: "AI reads the 50-page privacy policies nobody reads, and tells me what matters."

How it works (if they ask): The policy analyser safely downloads the page (blocking private network addresses), runs keyword checks for 8 risk types, then asks Gemini for a structured JSON verdict. Breach predictions are a transparent formula (category base rate, past breaches, missing 2FA, reuse).

BE ACCURATE: Breach prediction is a rule-based estimate, not a trained machine-learning model.

FEATURE 15

Timeline

Where: App: More > Timeline - Web: /timeline

What it is, in plain words. Your security history: a chart of your score over time and a ledger of events (accounts added, breaches found, fixes completed, score changes).

How to show it:

- Complete a fix on Overview, then open Timeline: the step chart rises and the event appears.

Say: "Progress you can see. Every fix moves the line."

How it works (if they ask): The score is recorded automatically whenever it changes; events are assembled from accounts, breaches, fixes, score history and the audit log.

FEATURE 16

Reports, Search, Notifications, Reminders

Where: App: More menu and bell icon - Web: /reports, /search, /notifications

What it is, in plain words. Reports: a full export of your security state. Search: find any account, breach or fix. Notifications: every alert in one inbox. Reminders: recurring security check-ups (e.g. rotate a password every 90 days).

How to show it:

- Open the bell after a breach scan.
- Export a report from the website.

Say: "Everything you need to stay on top of it, not just a one-time scan."

How it works (if they ask): A background monitor re-scans breaches on a schedule (default every 6 hours) and pushes new breach alerts live to the app over a WebSocket, so an alert can appear while the app is open.

FEATURE 17

Audit log (blockchain-style hash chain)

Where: App: More > Audit log (tabs Audit Log, Blocks) - Web: /blockchain

What it is, in plain words. A tamper-evident diary of every important security action: fixes confirmed, badges, lockdowns, proofs, identities, votes.

How to show it:

- Open Blocks: each block shows its hash and the previous block's hash, and the chain says VALID.
- Point out a receipt hash after confirming a fix on Overview.

Say: "If anyone edits my history, even one character, the chain breaks and the app shows exactly where."

How it works (if they ask): Each entry is a block: SHA-256 of (block number, previous block's hash, hash of the data, action, time). Because every block includes the previous hash, changing an old entry changes every hash after it. Verification recomputes the whole chain. Optionally (with a Polygon wallet key) each block hash is written into a transaction on the Polygon Amoy testnet for an independent public timestamp, with a Polygonscan link.

BE ACCURATE: It is a hash chain stored in our database, optionally anchored to Polygon. There is no smart contract, and anchoring is off unless a testnet wallet key is configured.

FEATURE 18

Zero-knowledge proof

Where: App: More > Audit log > ZKP tab

What it is, in plain words. Prove 'my privacy score is at least 70' to an employer, insurer or bank without revealing the actual score.

How to show it:

- Set the slider to 70, tap Generate proof (takes about 2 seconds of real 2048-bit maths).
- Tap Verify proof: VERIFIED. Tap Tamper 1 byte: REJECTED. Tap Claim +10: REJECTED.
- Set the slider above your real score: the app refuses, because such a proof cannot exist.

Say: "The verifier learns one bit of information: yes. Not my score, not my accounts. And it is mathematically impossible to fake."

How it works (if they ask): The score is hidden in a Pedersen commitment $C = g^{\text{score}} \times h^r$ over a 2048-bit prime group (RFC 3526). The server signs C with its Ed25519 key. To prove score ≥ 70 , the app shows that (score - 70) fits in 7 bits: it commits to each bit and attaches a Chaum-Damgard-Schoenmakers OR-proof that each one is 0 or 1 without saying which. The verifier multiplies the bit commitments back together and checks they equal C divided by g^{70} . Fiat-Shamir hashing makes it a single shareable package (about 14 KB). The verify endpoint is public and needs no login.

BE ACCURATE: The server holds the commitment's secret and builds the proof for you; the zero-knowledge guarantee protects you from the verifier (the bank learns only 'yes'). It is the same family as the range proofs in confidential crypto transactions.

FEATURE 19

Decentralised identity (DID)

Where: App: More > DID Identity

What it is, in plain words. A digital ID that you own, not a company. It carries a signed credential about your privacy score that anyone can check.

How to show it:

- Create an identity; show the did:key string and the credential.

Say: "My privacy reputation is portable. I carry a signed credential instead of a company holding my data."

How it works (if they ask): An Ed25519 key pair is generated; the public key becomes a standard W3C did:key identifier. The server issues a Verifiable Credential signed with its own Ed25519 key; anyone can verify the signature from the DID alone.

FEATURE 20

DAO voting

Where: App: More > DAO Voting

What it is, in plain words. Community governance: users report a suspected breach as a proposal, others vote, and at 5 'for' votes it becomes a confirmed breach report.

How to show it:

- Create a proposal; vote; show the vote counts.

Say: "Breaches get confirmed by the crowd before the official databases catch up."

How it works (if they ask): One vote per person per proposal, enforced on the server; confirmation notifies the author; proposals are recorded in the audit chain.

BE ACCURATE: Votes are stored in our database, not on-chain. Call it 'DAO-style community governance'.

FEATURE 21

Badges

Where: App: More > Badges - Web: /badges

What it is, in plain words. Achievements you earn and 'mint': Privacy Champion (score 90+), Security Pro (70+), 2FA Everywhere, Zero Reused Passwords, Breach Free, First Audit.

How to show it:

- Show an earned badge and its receipt hash.

Say: "Security is boring. Badges make it a goal."

How it works (if they ask): Eligibility is checked on the server; minting writes a block to the audit chain and stores the badge with that block's hash.

BE ACCURATE: Badges are recorded on the hash chain, not minted as on-chain NFTs.

FEATURE 22

Emergency lockdown and data broker opt-out

Where: App/Web: features menu

What it is, in plain words. Lockdown: one tap when you think you are hacked, giving an ordered recovery checklist for every account and a critical alert. Data brokers: a list of 8 people-search sites that sell your details, with their official opt-out links.

How to show it:

- Trigger lockdown on a test account and show the recovery steps.

Say: "When the worst happens, you get a plan in the right order: email first, then money, then everything else."

How it works (if they ask): Both are recorded in the audit chain.

BE ACCURATE: Lockdown gives advice and records the event; it cannot log you out of other companies' services. Opt-outs require submitting each broker's form.

FEATURE 23

Connection status and setup

Where: App: More > Connection status

What it is, in plain words. Shows which outside services are live (breach databases, AI, blockchain) and their last response time, so you always know what is real.

How to show it:

- Open it before the demo to confirm everything is green.

Say: "We are honest about what is connected. Nothing is faked."

How it works (if they ask): The backend reports each integration's mode (live, mock, unconfigured) and its last observed health.

PART 5

Glossary in plain words

Word	Simple meaning
2FA	A second check after your password, like a code. SMS codes are weak (SIM swap), authenticator apps are strong, passkeys are strongest.
SSO	'Sign in with Google/Apple/Facebook'. Convenient, but whoever owns your Google account owns all of those apps.
Recovery email	The inbox that receives 'reset your password' links. Owning it means resetting the account.
Password reuse	Using the same password on several sites. One leak opens them all.
Keystone account	An account that unlocks 5 or more others (usually your main email).
Breach	A company's data was stolen and leaked. HIBP keeps the public list.
Hash (SHA-256)	A fingerprint of data. Same input, same hash; change one letter and the hash changes completely; you cannot reverse it.
k-anonymity	Asking a question in a crowd: we send part of a hash that matches hundreds of passwords, so the server cannot tell which is yours.
Hash chain	Records where each one includes the previous one's hash, so editing the past breaks the chain.
Blockchain anchoring	Writing a hash into a public blockchain transaction to get a timestamp nobody can change.
Zero-knowledge proof	Proving a statement is true while revealing nothing else.
Pedersen commitment	A sealed, tamper-proof envelope for a number: it hides the number and you cannot swap it later.
Ed25519	A modern digital-signature algorithm. Proves who signed something and that it was not changed.
DID	Decentralised identifier: an ID derived from your own cryptographic key, not issued by a company.
DAO	Decisions made by community vote under fixed rules.
RAG	Retrieval-Augmented Generation: the AI first looks up relevant documents, then answers from them and cites them.
BM25	A classic search-ranking formula (used by search engines) that scores how well a document matches words in a question.
Embeddings	Turning text into numbers so similar meanings are close together, for smarter search.
AES-256-GCM / Keystore	Strong encryption, with the key locked in the phone's secure hardware so even the app cannot export it.
JWT	A signed login ticket the app sends with each request; it expires.
WebSocket	A live connection so the server can push alerts to the app instantly.

PART 6

Questions judges will ask

Q. Isn't this just Have I Been Pwned?

HIBP tells you if one email was in a breach. We use HIBP as one input, then map how your accounts unlock each other, simulate the attack across that network, and tell you the smallest set of fixes. HIBP has no graph, no simulation, no family view.

Q. Where does the data come from? Is it real?

Breaches come live from Have I Been Pwned and XposedOrNot. Accounts come from you, your installed apps or your password manager export. The Connection status screen shows exactly which sources are live.

Q. Do you store my passwords?

Never. Password exports are processed on the phone; only labels like 'reuse_1' leave it, and the server rejects any password field. The leak check sends only 5 characters of a hash.

Q. How accurate is the attack simulation?

It is a deterministic, explainable model: each link type has a success chance based on how real attacks work (SSO, password resets, credential stuffing) adjusted by the target's 2FA type. The goal is to rank risks and show which fix breaks the chain, not to predict an exact percentage.

Q. Why blockchain? Isn't that hype?

We only use it for one thing it is genuinely good at: a tamper-evident record. Each action is in a SHA-256 hash chain, and it can be anchored to Polygon for a public timestamp. We do not put personal data on-chain, only hashes.

Q. Is the zero-knowledge proof real?

Yes. Pedersen commitments with a bit-decomposition range proof using Chaum-Damgard-Schoenmakers OR-proofs, made non-interactive with Fiat-Shamir, on a 2048-bit group. We can show a tampered proof being rejected live.

Q. How does the AI avoid making things up?

Retrieval first: it gets the user's own records and the HIBP catalogue, must cite numbered sources, and the app shows which ones were cited. If no AI key is configured, it still returns the relevant records.

Q. What about family privacy?

Each member chooses Summary or Detailed sharing. Account names are hidden under Summary. Guardians can nudge, not read.

Q. How would this make money / scale?

Free for individuals; a paid family plan; and a B2B option where insurers or employers accept zero-knowledge proofs of good security hygiene without seeing personal data. The backend is stateless FastAPI and can move from SQLite to PostgreSQL.

Q. Is it tested?

39 automated backend tests cover breach scanning, the risk graph, RAG citations, Family Shield permissions, the attack simulator, the timeline and the zero-knowledge proof including tamper and forgery cases.

PART 7

What not to overclaim

A sharp judge respects accuracy. Use the wording on the right.

Avoid saying	Say instead
We store everything on the blockchain	Every action goes into a tamper-evident SHA-256 hash chain, optionally anchored to Polygon
NFT badges	Achievement badges recorded on our audit chain
Our DAO runs on smart contracts	DAO-style community voting on breach reports
We crawl the dark web	We monitor breach and paste sources through breach-intelligence APIs
Lockdown logs you out everywhere	Lockdown gives an ordered recovery plan and records the event
Our ML model predicts breaches	A transparent, rule-based risk estimate
Real attack success rates	An explainable model with expert-estimated hop probabilities
We read your email inbox	You paste an email, or import from your phone or password manager

PART 8

Checklist before you present

- Laptop: start the backend (`cd backend then python run.py`) and the website (`cd frontend then npm run dev`).
- Phone: plug in by USB and run `adb reverse tcp:8000 tcp:8000` so the app reaches the laptop.
- Open Connection status in the app: breach sources and AI should be live.
- Use a demo account with 8-12 accounts (or Smart Import). Run a breach scan once so real breaches appear.
- Complete one fix so the Timeline has a rising line and the audit chain has a receipt.
- Create a Family Shield group and join it from a second account before the demo.
- In Hack Me, check that Sample network runs; it is your safety net if anything else fails.
- Turn the phone's volume and vibration on: the vibrations during Hack Me are part of the effect.
- Keep the phone at full brightness and do-not-disturb on.
- Optional: set `POLYGON_PRIVATE_KEY` (a test wallet only) to show real Polygonscan links; `VOYAGE_API_KEY` for hybrid AI search.

Closing line:

Say: “Attackers think in chains. PrivacyShield is the first tool that lets ordinary people see the chain, break it, and prove it.”